

Code Audit Report

Полный аудит безопасности, перформанса, надёжности и качества кода. Тор-10 приоритетов + детальные находки по 9 категориям.

- P0 Critical
- P1 High
- P2 Medium
- P3 Low

ВЕРСИЯ	ДАТА	КАТЕГОРИИ
1.0	Май 2026	9

Содержание

Содержание
1. Security
2. Performance
3. Code quality / DX
4. UX / Accessibility
5. Reliability
6. Database
7. Monetization / Stripe
8. Observability
9. Deployment / CI
Top 10 priorities
Прочие важные находки (не вошли в Top-10, но скоро надо)

1. Security

- **P0** `useTaskComments.ts:33-58` — Realtime INSERT handler сломан: первый `setComments` всегда возвращает `prev` без изменений (`if (prev.some(...)) return prev` без `add-path`), новые комментарии добавляются только через вторичный chained query. Плюс нет `eq('workspace_id', ...)` фильтра — полагается только на RLS.
- Fix: переписать handler, добавить `workspace_id=eq.${currentWorkspaceId}` в realtime filter.
- **P1** `api/ai-ocr.ts:7-43` — `fileUrl` принимает любой HTTPS URL (`z.string().url()`). SSRF/abuse vector через провайдера модели.
- Fix: валидировать что host совпадает с Supabase storage и path начинается с `/storage/v1/object/public/document-attachments/` .
- **P1** `api/ai-assistant-chat.ts` — нет требования `requireWrite` (нормально для чата), но контекст из БД (titles задач/документов) попадает в system prompt без escape — prompt injection через ввод пользователя.
- Fix: жёсткое усечение полей, escape, ограничить доступ к чату до `member+` .
- **P1** `api/stripe-webhook.ts:53-110` — нет идемпотентности. Stripe ретраит тот же `event.id` , обработчик повторно делает UPDATE.
- Fix: таблица `stripe_webhook_events(event_id PK)` , INSERT с `ON CONFLICT DO NOTHING` .
- **P1** `api/stripe-webhook.ts:75 vs :65` — в `checkout.session.completed` plan жёстко `'pro'` , а в `customer.subscription.updated` — `price.id` (типа `price_xxxxx`). БД флипает между человекочитаемым и Stripe-ID.
- Fix: единый mapping `price.id → 'pro'|'team'|...` .
- **P1** `api/_lib/cors.ts:3-8` — fallback-список содержит превью-домен `synapseproject-tapclap364s-projects.vercel.app` . Если `ALLOWED_ORIGINS` забыли в проде, атакующий мог бы поднять превью на этом субдомене.
- Fix: в production отказывать стартовать без `ALLOWED_ORIGINS` .
- **P2** `src/types/index.ts:36` объявляет `is_super_admin?: boolean` на `Profile` , но в `database.ts:228-249` нет этой колонки. `profile?.is_super_admin` всегда `undefined` , Admin-ссылка в Header **dead code**.
- Fix: добавить колонку миграцией ИЛИ загрузить через отдельный запрос.
- **P2** `src/components/WorkspaceMembers.tsx:91-100` — смена роли клиентом напрямую через RLS. Нет guard против снятия **последнего owner**.
- Fix: перенести в Edge Function или Postgres trigger.
- **P3** `vercel.json:12` — добавить `accelerometer=()` и `payment=()` в `Permissions-Policy` .

2. Performance

- **P1** `src/App.tsx:243-244, 254-256, 276` — `Object.entries(epics).map(...)` пересчитывается на каждом рендере, передаётся в `KanbanView` , `EpicsView` , `TaskModal` . Каждый child перерендерится зря.
- Fix: `useMemo` в `App.tsx`.
- **P1** `src/components/GanttView.tsx:17-22, 56-59, 91, 107-133` — Вся CPM-геометрия и SVG paths пересчитываются на каждом рендере.
- Fix: `useMemo([cpmData])` , `React.memo(GanttBar)` .
- **P1** `src/hooks/useData.ts:90-107` — Realtime подписка на `tasks` триггерит **полный re-fetch** на каждое изменение.
- Fix: использовать `payload.new/old` для локальной мутации, полный fetch только при reconnect.
- **P1** `api/process-whiteboard-notes.ts:104-141` , `process-meeting.ts:124-138` , `create-task-from-voice.ts:86` — `sequential for ... await insert(...)` . N round trips.
- Fix: batch `.insert(arrayOfRows)` .
- **P2** `api/ai-assistant-chat.ts:20-25` — контекст из БД без truncation, легко вылетает за пределы context window.
- Fix: сар полей до 200 chars каждого.
- **P2** `vite.config.ts` — `lucide-react` (~1MB иконок) не выделен в отдельный chunk.
- Fix: добавить `lucide: ['lucide-react']` в `manualChunks` или per-icon imports.
- **P2** Аватары через DiceBear без `loading="lazy"` / `decoding="async"` .

3. Code quality / DX

- **P1** Тесты: 2 файла на весь проект. Нет тестов на `epicResolver.ts`, `auth.ts`, `useData`, `useTaskComments`, `KanbanView`, любые компоненты.
- Fix: минимум `epicResolver.test.ts` + `auth.test.ts`.
- **P1** `any` в 14+ местах. Худшие: `Whiteboard.tsx:16,21,36,119,124` (tldraw полностью untyped), `DocumentEditor.tsx:129,147,173` (`catch error: any`), `SearchModal.tsx:17,69`.
- **P1** Inline-style sprawl — 5 худших файлов: 1. `EpicsView.tsx` — hover handlers переписывают `currentTarget.style.*` вместо CSS `:hover`. 2. `AdminPage.tsx` — inline-style на каждой ячейке таблицы. 3. `WorkspaceMembers.tsx:144-205` — вся таблица inline. 4. `AIAssistant.tsx:53-167` — hardcoded `#fff` / `#3b82f6` ломают тёмную тему. 5. `MeetingModal.tsx:22-41` — hardcoded `#f0fdf4` / `#475569` ломают тёмную тему.
- **P2** Hardcoded русские строки несмотря на i18n: `AIAssistant.tsx:14-16`, `Auth.tsx:48,79`, `EpicsView`, `OnboardingTour`, `LandingPage`.
- **P2** `SentryErrorBoundary` экспортируется в `src/lib/sentry.ts:16` но **никогда не импортируется**. Sentry не видит React errors.
- **P2** `src/types/index.ts:6` — `Task.status` union содержит `'todo'`, но в DB enum только `'draft'|'backlog'|'in_progress'|'done'`. Schema drift.

4. UX / Accessibility

- **P1** `TaskModal`, `MeetingModal` — **нет focus trap, нет Escape-to-close, нет return-focus**. Только `SearchModal` обрабатывает Escape.
- Fix: `useModal()` хук или `@radix-ui/react-dialog`.
- **P1** Color contrast — `var(--color-text-muted)` на `var(--color-surface-alt)` (placeholder тексты в Kanban, Wiki, Admin) рискует не пройти WCAG AA в обеих темах.
- **P1** AI loading states — `AIAssistant.tsx:127` показывает «ИИ думает...» без `aria-live="polite"`.
- **P2** `Auth.tsx:185` — `<p onClick>` для переключения login/register, должен быть `<button>`.
- **P2** Form errors через `alert()` (Auth, WorkspaceMembers, TaskModal) — не styling, не announceable, блокирует UI.

5. Reliability

- **P0** `api/process-meeting.ts:111-138` — Meeting вставляется, потом tasks в цикле. Если task #3 падает — meeting и 2 задачи остаются. Нет транзакции.
- Fix: RPC `create_meeting_with_tasks(payload jsonb)` в одной транзакции.
- **P1** `api/orchestrate-tasks.ts:108-128` — то же самое: per-task update, silent error count.
- **P1** Все AI endpoints — single call без retry на 5xx/429 (`openai.ts:22` `maxRetries: 1`).
- Fix: `maxRetries: 3` с backoff.
- **P1** `api/_lib/sentry.ts:33-35` — `initSentry()` fire-and-forget. Первый запрос после cold-start может завершиться раньше чем Sentry загрузится → 500-ки не отправляются.
- **P2** `vercel.json` — `api/ai-assistant-chat.ts` НЕ имеет `maxDuration`, default 10s Hobby. Длинные ответы режутся.

6. Database

- **P1** `comments.user_id` — nullable. Возможны комментарии без авторов.
- **P1** Вероятно отсутствующие индексы (нужно подтвердить через `get_advisors`):
 - `comments(task_id, created_at)`
 - `tasks(workspace_id, status)`
 - `tasks(workspace_id, epic_id)`
 - `attachments(document_id)`
 - `workspace_members(user_id)`
- **P2** `documents.content` — inconsistent shape: `DocumentEditor` сохраняет строку, `generate-project-report` сохраняет `{html}`. Standardize на один формат + миграция.

7. Monetization / Stripe

- **P0** Нет ни одного feature gating по plan нигде в приложении. Search `w.plan` находит только display в `AdminPage.tsx:275`. Клиенты платят за `pro` — не получают ничего.

- Fix: добавить `useWorkspace().plan`, gate AI endpoints + UI с upgrade CTA.
- **P1** `stripe-webhook.ts:53` — нет `customer.subscription.trial_will_end` или `invoice.payment_failed`. Провалившиеся платежи не даунгрейдят план.
- **P2** Нет Billing Portal endpoint. Owners не могут самостоятельно сменить карту/отменить.

8. Observability

- **P1** Sentry frontend — `initSentry()` есть, но **нет SentryErrorBoundary в дереве**. React errors не идут в Sentry.
- **P1** PostHog — критические gaps в воронке:
 - Нет `user_signed_up`
 - Нет `workspace_created`
 - Нет `member_invited`
 - Нет `first_task_created`
 - Нет `plan_upgraded`
- **P2** Логирование на сервере — голый `console.error('[api-error]', err)` без request ID или workspace ID correlation.

9. Deployment / CI

- **P1** `.github/workflows/ci.yml` — нет deploy preview или e2e тестов. Только typecheck + lint + unit (которых ~0).
- **P1** Vercel env vars — упомянуть в README/runbook что нужны: `SUPABASE_URL`, `SUPABASE_SERVICE_ROLE_KEY`, `OPENROUTER_API_KEY`, `ALLOWED_ORIGINS`, `STRIPE_SECRET_KEY`, `STRIPE_WEBHOOK_SECRET`, `UPSTASH_REDIS_REST_*`, `SENTRY_DSN`, плюс frontend `VITE_*`.
- **Critical:** `ratelimit.ts:50-56` silently no-ops если Upstash не настроен — в проде нужна fail-fast проверка.
- **P2** Tldraw 2.4.6, Tiptap 2.2.4, Supabase 2.39.0 — отстают на 6-12 месяцев. Security advisories вероятны. Подключить Dependabot/Renovate.

Top 10 priorities

1. **[P0] Her plan-gating** при работающем Stripe. Owners платят за Pro — ничего не меняется.
2. **[P0] `useTaskComments.ts:33-58`** — broken realtime INSERT handler.
3. **[P0] `process-meeting.ts`** — partial-failure без транзакции.
4. **[P1] Stripe webhook** — отсутствует идемпотентность + plan-id inconsistency.
5. **[P1] `api/ai-ocr.ts`** — принимает любой HTTPS URL (SSRF).
6. **[P1] Modal a11y** — TaskModal/MeetingModal без focus trap, Escape, return focus.
7. **[P1] SentryErrorBoundary** не используется — React errors не идут в Sentry.
8. **[P1] Bulk-insert AI endpoints** — заменить per-row loops на batched insert.
9. **[P1] Test coverage ≈ 0** — добавить тесты на `epicResolver`, `auth`, `useTaskComments`.
10. **[P1] PostHog funnel gaps** — без `signed_up` / `workspace_created` / `member_invited` / `first_task_created` / `plan_upgraded` нет данных о конверсии.

Прочие важные находки (не вошли в Top-10, но скоро надо)

- `src/types/index.ts:36` `is_super_admin` нет в DB schema → Admin-ссылка в Header — dead code.
- `AIAssistant.tsx:91,118,131` hardcoded `#fff` / `#f8fafc` — ломают тёмную тему.
- `tasks.status` TS-type имеет `'todo'`, в DB enum нет — schema drift.
- `documents.content` shape inconsistent (string vs `{html}`) у разных writers.
- CORS `DEFAULT_ORIGINS` silently fallback — в проде нужна fail-fast.
- Upstash ratelimit silently no-ops если не настроен — то же самое.
- `useData.ts:90-107` full-refetch на каждый realtime change — O(N) per write.
- `lucide-react` не chunked — main bundle bloat.